Unit -I Introduction to Information Security

1.1 Introduction to Information Security

- ✓ Information security is the practice of protecting information by harmful information risks.
- ✓ Information can be a physical or electronic one
- ✓ Information security protects sensitive information from unauthorized activities, including inspection, modification, recording, and any disruption or destruction.
- ✓ This includes the protection of personal information, financial information, and sensitive or confidential information stored in both digital and physical forms.

1.2 Need for Security

- ✓ We use information security to protect valuable information assets from a wide range of threats, including theft and cybercrime.
- ✓ Information security is necessary to ensure the confidentiality, integrity, and availability of information, whether it is stored digitally or in other forms such as paper documents.
- ✓ Here are some key reasons why information security is important:

Protecting sensitive information: Information security helps protect sensitive information from being accessed, disclosed, or modified by unauthorized individuals. This includes personal information, financial data, and trade secrets, as well as confidential government and military information.

Mitigating risk: By implementing information security measures, organizations can mitigate the risks associated with cyber threats and other security incidents. This includes minimizing the risk of data breaches, denial-of-service attacks, and other malicious activities.

Preventing Cyber-attacks: Cyber-attacks, such as viruses, malware, phishing are becoming increasingly sophisticated and frequent. Information security helps prevent these attacks and minimizes their impact if they do occur.

Protecting Employee Information: Organizations also have a responsibility to protect employee data, such as payroll records, health information, and personal details. This information is often targeted by cybercriminals, and its theft can lead to identity theft and financial fraud.

1.3 Security Attacks: Active, Passive and Denial of Service

- ✓ Security attacks mean risk of the system's security.
- ✓ These are the unauthorized or illegal actions that are taken against the government, corporate, or private IT assets in order to destroy, modify, or steal the sensitive data.
- ✓ They are further classified into active, passive attacks and Denial of Service.

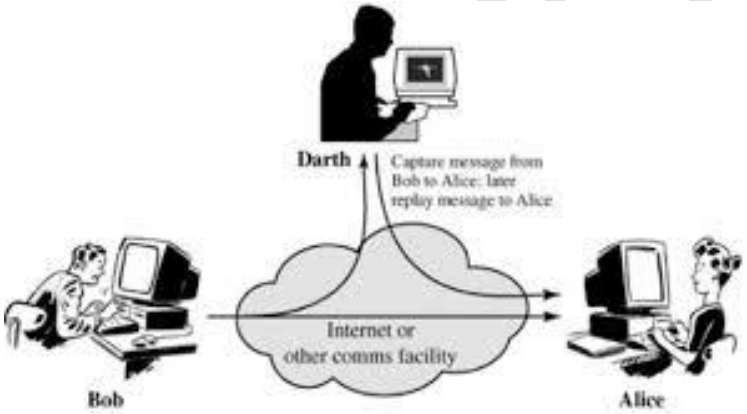
<u>Active attacks</u>

- ✓ An **active attack** involves modification of transmitted data, or the creation of new false data streams.
- ✓ There are four sub-categories here:
  1. **masquerade or fabrication,**
  2. **message modification**
  3. **message replay, and**
  4. **denial of service (DoS)**

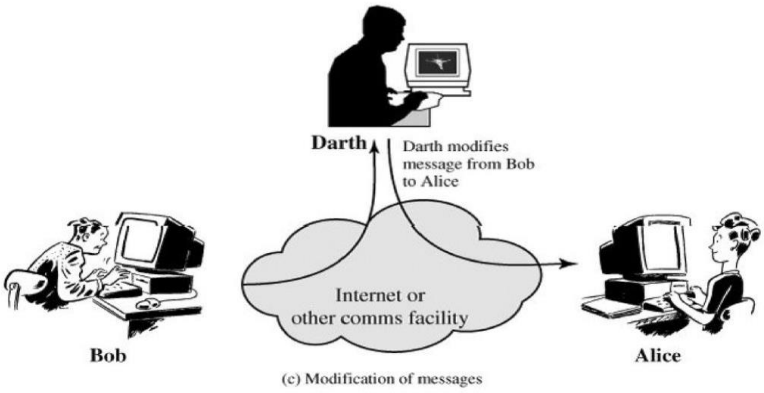
1. **Masquerade attacks**: It takes place when one entity pretends to be a different entity.

For example: authentication sequences can be captured and replayed after a valid authentication sequences has taken place.

2. **Message replay** it involves the passive capture of a data and its subsequent retransmission to produce an unauthorized effect.



3. **Message modification: To** produce an authorized effect, some portion of message is altered or that messages are delayed or reordered.



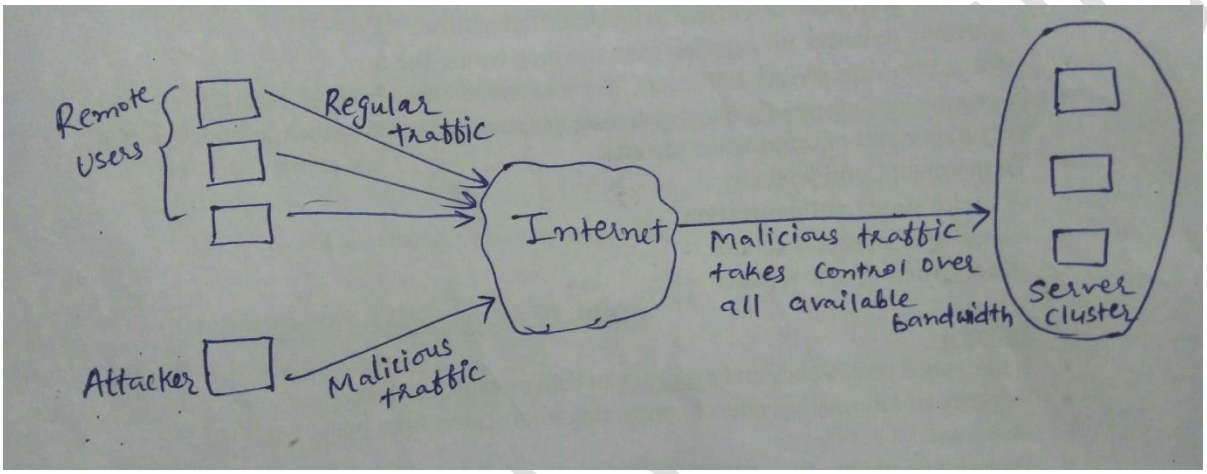
Active Attack – Modification of messages

4. Denial-of-service attacks prevent the normal use of communication services.

It disrupts network services either by disabling the network or overloading server with useless messages.

Denial-of-Service Attack

- ✓ It is Active attack.
- ✓ It is a special kind of Internet attack aimed at large websites.



- ✓ In DoS attack, disruption (interruption) of an entire network is done either by disabling the network or by overloading it with messages.
- ✓ DoS attack, is an explicit attempt to make a computer resource unavailable by flooding the network with useless traffic.
- ✓ It attempts to "flood" a network, thereby preventing legal network traffic.
- ✓ It attempts to disrupt (interrupt) connections between two machines, thereby preventing access to a service.
- ✓ It attempts to prevent a particular individual from accessing a service
- ✓ In DoS, One computer and one internet connection is used to flood server.

Effect of DoS attack:

- ✓ Slow network performance
- ✓ Unavailability of a particular website
- ✓ In ability to access any web site

Passive Attack: Attempts to learn or make use of information from the system but does not affect system resources.

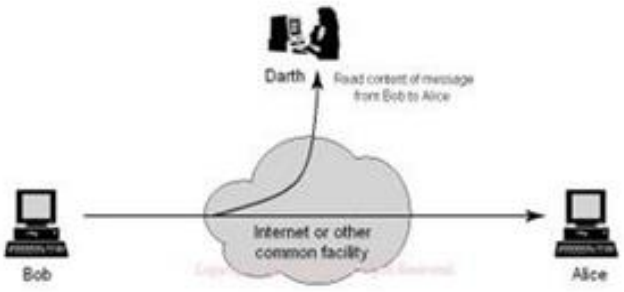
There are two main types of passive attacks:

1) Release of message contents and
2) Traffic analysis.

Passive attacks are very hard to detect because they don't damage or change the information.(so you can't tell they have been attacked.)

1. Release of Message contents

In this type of passive attack a mail message, phone call or any transferred message would be intercepted or listened to.



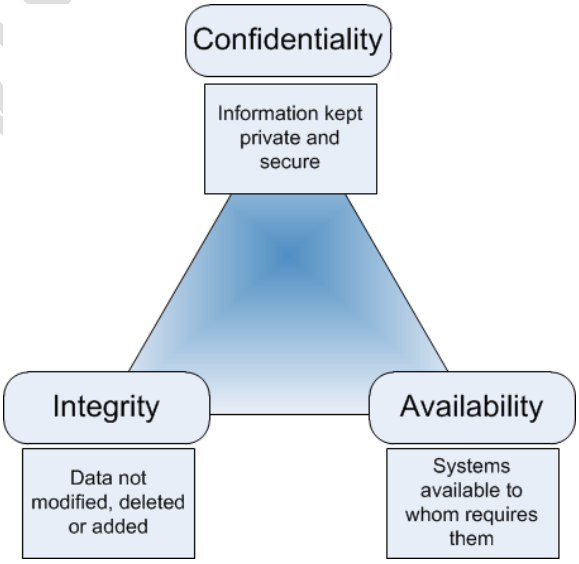
Release of message contents (Passive Attacks)

2. Traffic Analysis

Traffic Analysis is a little more complicated. Here the attacker observes the pattern of the message that is transferred between sender and receiver. Attacker may also observe frequency of occurrences of message and length of message.

1.4 Security Basics: Confidentiality, Integrity and Availability (CIA Model)

- ✓ CIA is a model design to guide policy for information security within an organization.



Confidentiality:

- ✓ It is a set of rules that limits access to information.
- ✓ It prevents sensitive information from reaching the wrong people.
- ✓ Confidentiality means that the data is only available to authorized parties.
- ✓ **Information kept private and secure**, like account no. when banking online.
- ✓ Everyone has information they wish to keep a secret. Protecting such information is a very major part of information security.
- ✓ When information has been kept confidential it means that it has not been compromised by other parties; confidential data are not disclosed to people who do not require them or who should not have access to them.

Example: account number when banking online

- ✓ To accomplish Confidentiality:
  - **Require strong authentication for any access to data.(**password, biometrics etc…)
  - Use strict access control(Privileges)
  - Encryption of the data

Integrity:

- ✓ It maintains **consistency** and **accuracy** of data over its entire life cycle.
- ✓ Integrity of information refers to protecting information from being modified by unauthorized parties.
- ✓ **Data should not modify, deleted or added in the way of transmission.**
- ✓ Information only has value if it is correct.
- ✓ If changes occur, a change copy must be available to restore the affected data.

Availability

- ✓ It means that the information is available to authorized users when it is needed.
- ✓ Information only has value if the right people can access it at the right times.
- ✓ This involves properly maintaining hardware and technical infrastructure and systems that hold and display the information.
- ✓ It is achieved by maintaining all hardware, hardware repairs immediately when needed, provide sufficient bandwidth and implement backup power system.

1.5 Services and Mechanisms

Security Services

- ✓ Security services are that enhances the security of the data processing systems and the information transfers of an organization.
- ✓ The intension is to counter security attacks. It involves use of one or more security mechanisms to provide the service.
- ✓ The main services of security are mention as below.

1) Authentication

- ✓ The authentication service is concerned with assuring that a communication is authentic.
- ✓ In the case of a single message such as a warning or alarm signal, the function of the authentication service is to assure the recipient that the message is from the source that it claims to be from.

2) Access Control

VPMP POLYTECHNIC

- ✓ The prevention of unauthorized use of a resource (i.e. this service controls who can have access to a resource, under what condition access can occur and what those accessing the resource are allowed to do.)
- ✓ The principle of access control decides who should be capable to access information or system through communication link. It supports the avoidance of unauthorized use of a resource.
- ✓ In the framework of information security, access control is the capability to check and control the approach to host systems and applications via communications connection.

3) Data Confidentiality

- ✓ The principle of confidentiality defines that only the sender and the intended recipient should be capable to create the element of the message. It protects the transmitted data from passive attack.
- ✓ Confidentiality can be used at several levels on the basis of content of information to be transmitted.

4) Data Integrity

- ✓ Data integrity is designed to secure information from modification, insertion, deletion and rehashing by any entity.
- ✓ Data integrity can be used to a flow of message, an individual message or a selected portion inside a message. Data integrity can be used to support total stream protection.

Types of Security Mechanism

1) Encipherment

- ✓ This security mechanism deals with hiding and covering of data which helps data to become confidential.
- ✓ It is achieved by applying mathematical calculations or algorithms which reconstruct information into not readable form.
- ✓ It is achieved by two famous techniques named Cryptography and Encipherment.

2) Access Control

- ✓ Access controls are used to restrict access to sensitive information and systems to only those who need it.

3) Notarization (authenticate)

- ✓ This security mechanism involves use of trusted third party in communication.
- ✓ It acts as mediator between sender and receiver so that if any chance of conflict is reduced.
- ✓ This mediator keeps record of requests made by sender to receiver for later denied.

4) Data Integrity

- ✓ This security mechanism is used by appending value to data to which is created by data itself.
- ✓ It is similar to sending packet of information known to both sending and receiving parties and checked before and after data is received. When this packet or data which is appended is checked and is the same while sending and receiving data integrity is maintained.

5) Authentication exchange

- ✓ This security mechanism deals with identity to be known in communication.
- ✓ This is achieved at the TCP/IP layer where two-way handshaking mechanism is used to ensure data is sent or not.

VPMP POLYTECHNIC